

A Cybersecurity Case Study Review of the Shwapno Customer Data Leakage Incident: Causes, Impacts, and Defensive Framework

Ashraful Islam Tanzil (0112230028), Md. Zawad Al Mahir (0112230117), Sameem Kuddus Nehal (0112230186)

Department of Computer Science and Engineering

United International University

Dhaka, Bangladesh

ID: 0112230028

Abstract—Modern retail organizations manage massive amounts of highly sensitive user data, making them primary targets for advanced cyber threats. This paper analyzes the double extortion ransomware attack suffered by Shwapno, Bangladesh’s largest supermarket chain. The breach compromised 410 Giga-bytes of data, exposing the sensitive personal information of approximately 4 million customers over a seven-month dwell time. We analyze the technical and organizational failures that facilitated this incident and formulate a risk assessment model based on the unique digital ecosystem of Bangladesh, where mobile numbers serve as identity and financial anchors. Finally, we propose and validate a practical, scalable, zero-licensing-cost Defense-in-Depth framework leveraging Wazuh for real-time intrusion detection and active response, alongside MyDLP for preventing critical data exfiltration.

Index Terms—Double Extortion Ransomware, Dwell Time, Data Loss Prevention, Wazuh, MyDLP, Zero Trust Architecture.

I. INTRODUCTION

Shwapno, a subsidiary of ACI Limited and Bangladesh’s largest supermarket chain with 812 outlets across 63 districts, suffered a massive cybersecurity breach [1]. The security incident involved a sophisticated ransomware attack coupled with the systematic exfiltration of sensitive organizational and consumer data. Although the initial compromise occurred in August 2025, it was not publicly disclosed until March 2026. This delay created a seven-month window of heightened, unmitigated risk for approximately 4 million registered customers.

This case study adopts an analytical approach to break down the attack lifecycle, dissect structural system vulnerabilities, and propose architectural remedies to build operational resilience within large-scale retail ecosystems.

II. PRELIMINARIES AND THREAT MODEL

A. Threat Model: Double Extortion Ransomware

The security incident is classified as a Double Extortion Ransomware attack [1]. Unlike traditional ransomware operations that purely encrypt localized files to demand a decryption fee, double extortion actors first exfiltrate confidential data assets before deploying encryption scripts. This guarantees

the threat actors maintain maximum leverage over the victim organization; even if the enterprise successfully restores its operational state from offline backups, the attackers threaten to leak or sell the stolen datasets to competitors or public forums.

B. Key Operational Definitions

- **Dwell Time:** The continuous duration during which a malicious actor operates inside an enterprise network undetected. In the case of Shwapno, the dwell time spanned approximately 7 months [1].
- **Initial Access:** The definitive entry point or vector exploited by a threat actor to establish a foothold inside the target environment. This incident utilized targeted spear-phishing campaigns.

C. Mathematical Risk Formulations

To mathematically evaluate the posture of the enterprise during the incident, we employ two primary formulas:

1) *Risk Assessment Framework:* The overall risk of an active incident is the product of attack probability and severity:

$$Risk_{incident} = P_{attack} \times S_{incident} \quad (1)$$

Given the massive scope of Shwapno’s centralized database, the system severity index ($S_{incident}$) is classified as **High** [1].

2) *Impact and Expected Loss Metric:* The expected financial and operational loss ($E[L]$) is evaluated as:

$$E[L] = P_{breach} \times L_{breach} \quad (2)$$

where L_{breach} is the total volume of affected consumer nodes (40 Lakh / 4 million customers) and P_{breach} is the specific sensitivity weight allocated to the exposed data types [1].

III. ROOT CAUSE ANALYSIS AND IMPACT ASSESSMENT

A. Technical and Organizational Failures

The breach resulted from a systemic breakdown of defense controls across technical and organizational domains [1]:

- **Initial Compromise via Phishing:** Threat actors distributed crafted spear-phishing emails targeting corporate personnel to harvest internal directory credentials.

- **Lack of Network Segmentation:** The internal network entirely lacked structural micro-segmentation or perimeter isolation. Once initial entry was achieved, attackers moved laterally unobstructed from the employee workstation layer to high-value servers hosting the customer database.
- **Insufficient Monitoring Systems:** The enterprise operated without an active Security Information and Event Management (SIEM) tool or Data Loss Prevention (DLP) solution. Consequently, the prolonged presence of attackers and the massive outbound exfiltration of 410 GB of data triggered zero alerts.
- **Human Factor and Training Gaps:** The success of the initial phishing vector highlighted a severe lack of regular, mandatory security awareness training for corporate employees.
- **Delayed Incident Response:** Executive management initially accepted basic technical assurances that operational data was recovered, neglecting to promptly retain specialized, external digital forensics and incident response (DFIR) specialists.

B. Multi-Dimensional Impact Assessment

The exposure of 410 GB of data caused severe real-world harms amplified by the localized digital infrastructure of Bangladesh:

Within Bangladesh, mobile numbers are linked biometrically to National Identity (NID) cards and serve as the core authentication mechanism for Mobile Financial Services (MFS) like bKash and Nagad. This leaked database provided threat actors with a verified target list of 4 million names and phone numbers, exposing citizens to highly targeted financial fraud and identity theft [1].

The 410 GB of exfiltrated data was not limited to customer profiles; it included proprietary supplier contracts, internal corporate sales metrics, and sensitive corporate HR records. This induced a catastrophic loss of brand trust, a formal General Diary (GD) filing with the Tejgaon Industrial Area Police, investigations by the Counter Terrorism and Transnational Crime (CTTC) unit, and structural regulatory scrutiny under regional cybersecurity legislation [1].

IV. METHODOLOGY

This research adopts a case study-based analytical approach integrating threat modeling, root cause analysis, and security design to build an actionable cybersecurity framework. Data was collected from public breach listings, expert forensic analyses, and official investigative findings. By analyzing each stage of the attack lifecycle—from initial access through execution—we map explicit defensive controls to reduce attacker dwell time and prevent unauthorized outbound data movement.

V. PROPOSED DEFENSE-IN-DEPTH FRAMEWORK

To transition from a vulnerable, reactive posture to an active defensive state, we propose a scalable, zero-licensing-cost architecture [1].



Fig. 1. Multi-Dimensional Impact Severity Score Framework [1].

A. Technical Enhancements & Governance

- 1) **Identity Control:** Enforce enterprise-wide Multi-Factor Authentication (MFA) and strict Privileged Access Management (PAM) policies.
- 2) **Zero Trust Architecture (ZTNA):** Transition to strict network micro-segmentation so that compromised end-user nodes cannot establish connections with high-security database clusters.
- 3) **Resilient Backup Engineering:** Implement a strict 3-2-1 backup strategy (3 copies of data, across 2 different media formats, with 1 copy stored securely offsite) utilizing immutable, read-only storage architectures to neutralize encryption routines.
- 4) **Governance Controls:** Appoint a dedicated Chief Information Security Officer (CISO), mandate quarterly employee phishing simulations, and align processes with ISO 27001 standards [3].

B. Core Architectural Components

1) *Wazuh (The Early Warning System):* Wazuh is an open-source, enterprise-ready security monitoring platform deployed via endpoint agents to provide real-time behavior analysis.

- **File Integrity Monitoring (FIM):** By tracking cryptographic hashes of system binaries, FIM immediately flags unauthorized modifications or persistence scripts used by attackers to maintain long-term access.
- **Active Response:** If an endpoint agent detects credential harvesting behaviors, malicious command execution, or lateral scanning vectors, Wazuh can execute automated firewall blocks at the local system level to contain the threat instantly.

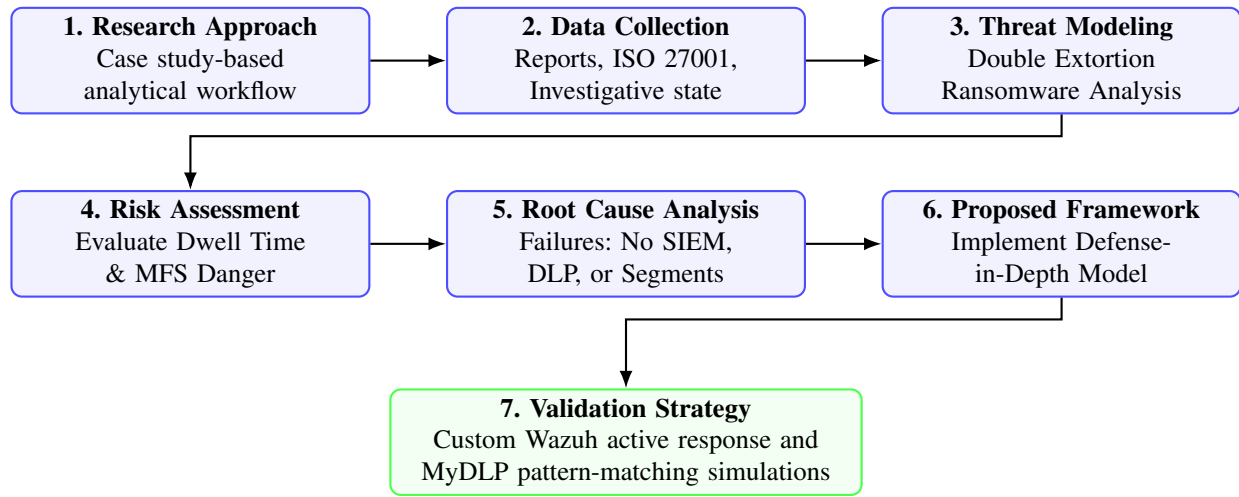


Fig. 2. Systematic Methodology Flowchart Mapping the Incident Assessment to Validation Architecture.

- **Economic Viability:** Because it is open-source and carries zero licensing overhead, it scales seamlessly across 812+ physical retail branches without financial strain.

2) *MyDLP (The Data Guard)*: MyDLP acts as a data traffic inspection filter monitoring all network-egress points.

- **Data-in-Motion Filtering:** Administrators configure contextual rules restricting the transfer of structured records matching regex string patterns for mobile phone numbers or customer records. If an insider or external attacker attempts to exfiltrate massive files to cloud-storage destinations, MyDLP drops the session and alerts operations.
- **Endpoint Device Control:** Blocks unauthorized file transfers to physical external media (e.g., USB mass storage drives), systematically eliminating physical exfiltration vectors.

VI. SIMULATION AND CODE-LEVEL VALIDATION

To validate the proposed Defense-in-Depth architecture, a localized virtual simulation sandbox was built. The codebase, configurations, and automation scripts are documented in the project repository: <https://github.com/ai-tanzil811/cyber-security-project.git> [2].

A. Wazuh Agent Custom Rule Enforcement

A target server configuration was simulated running a Wazuh agent directed by a central manager. Custom detection rules were written to target the exact techniques used in the Shwapno breach:

- **Credential Harvesting Detection:** A rule was established to monitor access logs for atypical automated credential verification behavior.
- **Active Response Intervention:** An active response script was linked to this detection rule. Upon triggering, the agent executes an automated shell command that updates

local `iptables` or firewall dropping rules, immediately severing the attacker's incoming IP stream. This directly mitigates the 7-month dwell time vulnerability by shrinking the discovery and containment window down to milliseconds.

B. Data Loss Prevention (DLP) Signature Matching

To simulate the exfiltration phase where 410 GB of customer profiles were extracted, we engineered a validation script that replicates data-in-motion scanning:

- **String Array Matching:** The DLP simulation parses network streams using custom data pattern inspection routines. It scans outbound payloads for structural characteristics of Bangladeshi mobile formats (e.g., matching regular expressions for standard operators like +8801...).
- **Session Terminations:** When the script identifies an outbound sequence attempting to push data chunks exceeding the defined risk threshold, the rule triggers an immediate packet drop routine. This provides technical verification that even if a perimeter firewall is completely bypassed, the data loss prevention layer stops massive customer datasets from leaving the corporate ecosystem.

VII. CONCLUSION

The double extortion data breach of Shwapno serves as an essential warning for retail enterprises in developing digital economies. When customer databases are tied directly to National Identification frameworks and Mobile Financial Services, a corporate network compromise becomes an immediate threat to citizen financial security. This paper demonstrates that resolving these vulnerabilities does not require prohibitive licensing fees. By adopting a disciplined Defense-in-Depth approach—combining structured governance with open-source tools like Wazuh and MyDLP—organizations can eliminate visibility blindspots, suppress attacker dwell time, and secure sensitive corporate and consumer assets against sophisticated threat groups.

REFERENCES

- [1] Case Study Documentation: A Cybersecurity Case Study Review of the Shwapno Customer Data Leakage Incident: Causes, Impacts, and Preventive Strategies.
- [2] Technical Repository and Active Simulation Sandbox: <https://github.com/ai-tanzil811/cyber-security-project.git>.
- [3] International Organization for Standardization, *ISO/IEC 27001: Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*, 2022.